

Before we build.

Thirteen questions to lock the MVP scope — in your words, not ours.

WHY THIS DOC EXISTS

This is the one-page discovery document referenced in the SecOps plan deck. The goal is simple: make sure what we build in weeks 3–5 is what you actually need, not what we assumed you need.

Short answers are fine. One or two sentences each is plenty. If something's unclear or doesn't apply, write "skip" and we'll cover it live. If you want to hand-write or voice-note an answer, that works too, just send it back however's fastest.

Prepared for: Jim Blankenship (product owner) and Sibe Klomp (primary user). Please return by: 4/24/26 or whenever's easy.

Comment legend:

Green = Sibe

Blue = Jim

01

Primary user & the one job

Q01. Who is the primary user for phase 1: operator, manager, sales, or client?

Our current assumption: Sibe and the SOC analysts are the phase 1 users. Phase 2 adds customer-facing. Confirm or correct.

ANSWER

SOC Team would be primary users, currently 11 employees. Perhaps that we'd want to give the Account Managers access to view their respective customer's data as well at some point. The SOC team will be able to manually create tickets as the customer requests come through, so customer-facing page would be of lower importance in my opinion.

SOC team. Other roles are bonus but unnecessary for MVP.

Q02. What is the single most important job this MVP must do in the first 5 weeks?

If we only ship one thing, what is it? (We've been assuming: remove the manual email ↔ Snyder copy-paste.)

ANSWER

Remove having to manually create the email communication from scratch, which promotes user-error - automatic customer recognition automatically filling in recipients as the ticket is created from SNYPR. (all logs/events contain the customer's name)

Create tickets (either manually or through API), log activity on said ticket, and follow that through resolution.

02

Current workflow & where it breaks

Q03. Walk us through the real alert-to-client workflow today — from detection to notification. Where does it actually break?

Not the intended workflow. The real one, with shortcuts, Slack threads, and where things get lost.

ANSWER

Incident is generated in SNYPR -> analyst claims, investigates, and deems it requires communication -> draft email in gmail, grabbing the pertinent information from the incident (e.g. username, IP address, country info, count of occurrences, etc), pasting screenshot where applicable -> look in Hudu (our KB portal) for the customer's contacts -> copy email addresses and paste them in gmail's to field -> send from our shared SOC address -> move incident to "awaiting customer" state in SNYPR -> paste the sent email into the incident's comments in SNYPR -> once customer responds, copy response and paste it in incident comments in SNYPR -> close incident in SNYPR

Where things go wrong:

SOC analyst grabs the wrong contact information, sending the email intended for one customer to another

Forgetting to move incidents to "awaiting customer" state

Forgetting to add sent email to the incident's comments

Once customer responds, not closing the incident in SNYPR

Sibe is closer to this than I. One thing of note not called out above is, depending on customer preference, we send these communications via email, or Slack (trying to move away from Slack for initial escalation to standardize our processes, plenty of clients never want to touch Slack), or occasionally (if critical) via phone.

Q04. What are the 2–3 alert sources we must ingest for the pilot?

Snyper (Securonix SIEM) is confirmed. What else? SentinelOne direct? CrowdStrike? Huntress?

ANSWER

Securonix SNYPR SIEM, Huntress (we receive automated emails), CrowdStrike/SentinelOne (both offer API integrations, CS has more actions available than S1)

I'd start with Sibe's recommendations. Securonix SIEM and EDR products (Huntress, SentinelOne, CrowdStrike)

Q05. What is the minimum data an operator needs on one screen to make a decision fast?

Customer name, incident summary, severity, asset, related alerts — what else? What's non-negotiable?

ANSWER

Depends on the platform/how we see the activity. But generally, which customer, which platform the alerts/notifications are for, the severity of the detection, the type of detection that was made, etc.

Most of the data is funneled into Securonix if they're a SIEM customer. If they are not, regardless, the important data would likely be customer, event type, severity, affected services/machines, etc. Depending on how the platform is built, some form of timestamp from event creation with every action/communication would be nice.

03

Workflow states & actions

Q06. What are the minimum workflow states we need for phase 1?

Sibe mentioned Sniper has: open → claim → (expected activity / awaiting customer / completed). Are those the right states for the ticket system too? Anything missing?

ANSWER

When creating a ticket from SNYPR, maybe we can auto assign the ticket to the user who ran the playbook to create the ticket.

Open, Claimed, Awaiting Customer, Completed states are the most important

Claimed - where it is assigned to whoever picked claimed it

Awaiting Customer - where we maybe can set an expiration/auto-reminder if client doesn't respond

Completed - where possible this would also send the information to SNYPR and close out of the incident there

Each step adding a comment, or changes the state, on the incident in SNYPR's side

I believe those 4 stages are adequate. If we wanted others, we could incorporate others like this:

New/Open (unassigned alert)

Assigned (assigned to a specific analyst)

In Progress/Investigating (analyst working)

Escalated (passed to higher tier)

On Hold/Pending (waiting for info)

Resolved/Closed (remediated)

Canceled/False Positive (authorized activity or an error)

Q07. When does an alert become something the client needs to know about?

Today this is analyst judgment. What are the triggers? Severity threshold? Asset type? Specific detection patterns?

ANSWER

Analyst judgement

Severity ratings provided by the product platform we're managing (example: If S1 categorizes it as critical, we would likely categorize it as the same after a bit of investigation). The rest is mostly analyst judgment.

Q08. What client actions, if any, should be allowed: acknowledge, approve, override, add context?

Assuming any customer interaction in phase 1 is read-only or acknowledgment-only. Push back if that's wrong.

ANSWER

I agree with the assumption

If we want to allow client actions in phase 1, I can't think of any other client actions to add. Those seem adequate.

04

Friction, audit, scope

Q09. What needs to happen in under 30 seconds for the operator, or they will bypass the tool?

The Halo failure mode. Name the action that has to be fast or analysts will revert to email.

ANSWER

Upon determining the incident/alert needs to be communicated, we need to be able to hit a button/change state of the incident so that a ticket is created, the correct customer is assigned allowing for pre-filling of email contacts, some information is pulled straight from the incident data (usernames, IPs, timestamp, whatever pertinent). The ticket is assigned to whomever owns the incident, allowing them to quickly find it in their ticketing queue, able to jump right into finishing the writing of the email

We never even got to ticketing in Halo, beyond setting up the ticketing@vdalabs.com email to auto-create a ticket in the Halo dashboard. I guess a “nice to have” would be some AI assisted investigation about the alert or the context of the alert. Our SIEM platform pulls in a bunch of threat intelligence database feeds to categorize events and help make decisions but maybe something “out of band” that aids the analyst in investigation so it is less investigation and more action (or at least faster response)

Q10. What currently lives in Slack or people's memory that must move into the system first?

SLA clocks running in analyst heads. Customer context tribal knowledge. Follow-up reminders. What else?

ANSWER

Follow up reminders is a big item. Also, analysts keep incidents in an incomplete state for too long (e.g. incident staying in “claimed” status for days/weeks)

Manually having to check past communicated incidents to see if the customer notified us already/marked something as expected.

Also as Jim mentioned, customers send us notices in Slack letting us know users will be traveling. We now have to reference Slack when we get an incident to see if the customer has previously notified us of said activity.

We don't have “official” SLAs. And if we did, we have no means of tracking them accurately. We obviously prioritize activity based on event severity. A lot of the customer context stuff is stored in HUDU today. There are occasions when customers may give us a heads up about something (like...“hey, this guy is going to be in Brazil for 2 weeks” or “I’m going to bypass XYZ user’s MFA right now” or “I’m deleting a bunch of files in Sharepoint if you see any wild activity”) and that information is primarily in Slack. I do not know if analysts are also putting that information in HUDU or not.

Q11. What is the minimum audit trail we need so nothing gets dropped?

Every ticket change timestamped? Every email logged? Customer responses threaded? What would an audit of last month's incidents need to show?

ANSWER

Change timestamps, activity stream showing which user (internal/customer) took what action on a ticket. Any API actions taken. Some of this stuff can be hidden to normal users, or have a selection to show "system" events and "user" events.

Ticket timestamps, all responses logged against the ticket (I don't know if a Slack message would count as a response or not...not sure), maybe an internal metric of mean time to detect and mean time to resolve...Probably not necessary for phase 1 MVP but it would be nice to be able to pull a report against individual clients or our whole customer base and show the number of alerts, number of false positives, average response time, etc.

Q12. What should be out of scope for the 5-week build? What would make this feel like "Halo 2.0" — so we can avoid it?

Our current out-of-scope list: CRM, quotes, invoices, agreements, project management, knowledge base, scheduled meetings. Anything we should add to that list?

ANSWER

Anything not pertaining to SOC operations, such as sales or project management.

Unless it's unnatural or requires an integration of some sort, I'd just focus on SOC ticketing for phase 1. We learned that doing too much at once (like with Halo) was not a smart play.

05

Success metrics & ownership

Q13. What are the success metrics for the pilot: time to client, adoption, clarity, Slack reduction, something else? And who owns adoption after go-live so this does not die the same way Halo did?

This is the most important question. Halo didn't die because of bad software. It died because no one owned adoption. Who does, this time?

ANSWER

Full communicated incident workflow.

- Incident needing to be communicated
- Creation of ticket from SNYPR
- successfully sending of properly formatted email to customer (individual email signatures)
- smooth customer experience where they can reply to the email and it gives them a notice "your response has been logged under ticket ###"
- SOC being able to see customer response and take action on the ticket from there
 - E.g. mark as resolved, being able to respond to their message, etc.
- Once marked resolved, close the incident in SNYPR

Success metrics would probably be proving that a 1) manually created ticket by the customer, 2) manually created ticket by our SOC, and 3) auto-created ticket via API all function as expected from creation to resolution. Adoption ownership will lie primarily with Sibe and his team. I can obviously help where necessary.

HOW TO RETURN THIS

Whichever is easiest for you:

- Type answers into this doc and send back
- Reply in the shared Slack channel, one answer per message
- Voice-note it — we'll transcribe and send back for confirmation
- Schedule 30 minutes, we'll walk through it live

Thanks for the time. This doc is the thing that prevents us from building the wrong product in weeks 3–5.